AWESOME CYBER SECURITY HEAVEN — REALM DOSSIER · 2026 EDITION

The Armory

Offensive Security, Pentesting & Bug Bounty Tools

273	910,873	67%	155
FREE TOOLS	COMMUNITY STARS	ON GITHUB ACTIVE	ACTIVE IN 2026

273 tools · Part of Awesome Cyber Security Heaven — 1481 curated free tools across 14 realms · Data verified 2026-11-14 (re-verified monthly)

CURATOR'S NOTES

The workhorse realm — what you load onto a VPS before a bug-bounty session. Injection proof engines, parameter mining, crawl-and-fuzz chains dominate. We license-check hard here because copyleft contamination matters when findings end up in commercial reports.

MAINTENANCE SNAPSHOT (2026-11-14)

- **Active in the last 30 days:** 90 of 230 tracked GitHub repos (39%)
- **Quiet classics (no push in 12+ months, still listed):** 73 tools (marked ⏳ in the table) — 18-month Legacy Vault review queued for the quarterly pass
- **Earliest entries:** graudit (2009), WhatWeb (2010), JTAGenum (2010)

FLAGSHIP PICKS — THE HEAVYWEIGHTS

TOOL	★ STARS	CREATED	LAST PUSH	WHAT IT DOES
Metasploit Framework	39.3k	2011	2026-10-30 ✅	Metasploit Framework
sqlmap	38.8k	2012	2026-10-30 ✅	Automatic SQL injection and database takeover tool
Nuclei	32.5k	2020	2026-10-30 ✅	Nuclei is a fast, customizable vulnerability scanner powered by the global security community and built on a s…
masscan	26.1k	2013	2026-10-05 ✅	TCP port scanner, spews SYN packets asynchronously, scanning entire Internet in under 5 minutes.
MobSF	22.1k	2015	2026-11-01 ✅	Mobile Security Framework (MobSF) is an automated, all-in-one mobile application (Android/iOS/Windows) pen-tes…
RustScan	20.7k	2020	2026-10-20 ✅	🤖 The Modern Port Scanner 🤖

Full inventory — 273 curated tools · ranked by GitHub adoption · 2026-11-14 census · non-GitHub tools listed without stars

TOOL	★ STARS	CREATED	LAST PUSH	LICENSE / TIER
Metasploit Framework	39.5k	2011	2026-11-11 ✅	— the world's most-used pentest framework; thousands of validated modules for exploitation, post-engagement evidence gathering and reporting in authorized tests. Used by professional penetration testers and red teams in authorized engagements; the open-source counterpart to commercial exploitation platforms like Core Impact and Cobalt Strike.
sqlmap	38.9k	2012	2026-11-10 ✅	— the definitive SQL injection detection and exploitation tool for authorized web application testing. Used by penetration testers everywhere for SQL injection proof; the definitive free SQLi automation tool with no real commercial equal. (GPL-2.0)
Nuclei	32.8k	2020	2026-11-11 ✅	— template-driven vulnerability scanner; the huge community template corpus gives it detection breadth no single scanner matches. Used by bug bounty hunters and enterprise security teams alike for template-driven scanning at scale; a free staple that rivals paid web-scanning engines for public attack-surface checks.
masscan	26.1k	2013	2026-10-05 ✅	— the fastest TCP port scanner on earth; scan the whole internet in minutes — on networks you're authorized to test. Used by researchers and recon teams for internet-scale port discovery. (AGPL-3.0)
MobSF	22.2k	2015	2026-11-11 ✅	— all-in-one mobile app security: static + dynamic analysis for Android/iOS in a single pipeline. Used by mobile app security testers for static and dynamic analysis; the open-source alternative to commercial mobile app testing suites. (GPL-3.0)

Mimikatz	22k	2014	2026-10-30 ✅	— Well-known Windows credential extraction tool pulling plaintext passwords, NTLM hashes, and Kerberos tickets from LSASS. Used by red teamers and penetration testers; the canonical credential-dumping utility.
RustScan	20.7k	2020	2026-11-04 ✅	— modern Rust port scanner that finds open ports in seconds and pipes them straight into Nmap. Used by bug bounty hunters and sysadmins for fast port discovery with Nmap piping; a modern free alternative to legacy scanners. (GPL-3.0)
Bettercap	20.3k	2018	2026-11-10 ✅	— the Swiss-army knife for authorized network assessments: ARP/DNS spoofing, MITM proxies, WiFi and BLE modules. Used by network penetration testers for authorized MITM analysis; the modern successor to Ettercap in most toolkits. (GPL-3.0)
Zphisher	17.2k	2019	2024-08-21 ⏳	— Advanced phishing tool with tunneling support for exposing local phishing pages. Used by security researchers and penetration testers; a widely starred social-engineering framework. (GPL-3.0)
Impacket	16.3k	2015	2026-11-11 ✅	— the standard Python library for low-level Windows protocol work (SMB, LDAP, Kerberos); powers wmiexec/secretsdump-class tooling and AD assessments. Used by red teamers and AD security researchers; the Python underpinning of countless offensive and defensive toolkits.
OWASP ZAP	16.2k	2015	2026-11-11 ✅	— the open-source intercepting proxy and scanner — a full free Burp alternative with CI/CD integration and a big add-on ecosystem. Used by web pentesters, QA teams and bug bounty beginners.
Evilginx2	15.9k	2018	2026-06-10 ✅	— Phishing toolkit using reverse proxy to capture credentials and session tokens. Used by red teams; a powerful free adversary-in-the-middle tool. (BSD-3-Clause)
SET (Social-Engineer Toolkit)	15.5k	2012	2026-06-04 ✅	— Advanced framework for social engineering attacks including phishing and credential harvesting. Used by penetration testers; a well-known free offensive toolkit.
XSStrike	15.3k	2017	2025-04-26 ⏳	— Cross-site scripting detection and exploitation tool with advanced payload generation and fuzzing. Used by web pentesters; a capable XSS-focused scanner. (GPL-3.0)
Wifiphisher	15k	2014	2026-05-22 ✅	— Rogue access point framework for automated Wi-Fi phishing attacks, capturing credentials via fake captive portals. Used by red teamers; a well-known Wi-Fi phishing toolkit. (GPL-3.0)
Gophish	14.4k	2013	2024-09-23 ⏳	— Open-source phishing toolkit for awareness training and authorized testing campaigns. Used by security teams; a popular free phishing simulation platform.
RouterSploit	13.3k	2016	2026-05-05 ✅	— Exploitation framework targeting routers, IoT, and embedded devices. Used by penetration testers and red teams; a popular offensive tool for network devices.
THC-Hydra	12.5k	2014	2026-11-08 ✅	— the classic parallelized login cracker for 50+ protocols; password audits only on systems you own or are paid to test. Used by pentesters for authorized login audits across 50+ protocols; the classic parallelized cracker with no commercial equal. (AGPL-3.0)
hetty	12.5k	2019	2026-07-21 ✅	— HTTP toolkit for security research: an intercepting proxy with scope rules, request composer and replay, and a GraphQL management API in one self-hosted Go binary. Used by security researchers and bug hunters who want a scriptable, self-hosted proxy workbench; the open-source HTTP research toolkit. (MIT)
Sliver	12.3k	2019	2026-11-08 ✅	— Command-and-control framework for adversary simulation and red teaming. Used by red teams and security researchers; a modern offensive C2 platform. (GPL-3.0)
BeEF (Browser Exploitation Frame…	11.1k	2011	2026-11-11 ✅	— Browser exploitation framework that hooks browsers for client-side attacks. Used by penetration testers and red teams; a classic offensive security platform.
Red-Teaming-Toolkit	10.9k	2018	2026-05-07 ✅	— curated index of adversary-emulation and red-team tradecraft resources. Used by red teamers planning their tooling stack. (curated list)
Nikto	10.9k	2012	2026-11-09 ✅	— venerable web-server scanner; noisy but thorough on server misconfigurations and default files. Used by web server auditors for two decades; the venerable free complement to commercial web scanners' misconfiguration checks. (GPL-3.0; DB files have custom terms)
webshell	10.8k	2013	2024-12-24 ⏳	— Open-source collection of webshells for various languages and platforms. Used by red teamers and pentesters; a reference repository of web-based implants. (MIT)

WPScan	9.8k	2012	2026-11-07 ✅	— black-box WordPress scanner: plugin/theme enumeration and version-based vuln lookups. Used by WordPress security auditors and managed-service providers; the standard black-box WordPress scanner, free alternative to paid WP security suites. (free for non-commercial use)
objection	9.5k	2017	2026-10-27 ✅	— Frida-powered runtime exploration toolkit for mobile apps — inspect and manipulate iOS/Android at runtime. Used by mobile pentesters for runtime exploration without jailbreaks; the go-to Frida front-end for mobile engagements. (GPL-3.0)
BYOB (Build Your Own Botnet)	9.5k	2017	2026-10-18 ✅	— Post-exploitation framework and C2 platform that generates cross-platform encrypted binaries with multi-stage delivery chains and reverse shells. Used by red teamers and researchers; a full-featured botnet-style command and control toolkit. (GPL-3.0)
trape	9.1k	2017	2024-06-20 ⏳	— Open-source session-based person tracking and reconnaissance framework. Used by penetration testers and OSINT investigators; a powerful tracking and exploitation toolkit. (MIT)
FuzzDB	9k	2015	2023-11-10 ⏳	— Dictionary of attack patterns and primitives for black-box fault injection and resource discovery. Used by pentesters; a classic fuzzing payload collection.
how2heap	9k	2016	2026-11-06 ✅	— Educational repository of heap exploitation techniques with example code. Used by CTF players and security students; a well-known learning resource for heap bugs. (MIT)
Tsunami	8.6k	2020	2026-10-06 ✅	— Google's security scanner for large fleets, focused on reliably exploitable high-severity flaws with few false positives. Used by security teams scanning large fleets of internet-facing services; Google's open-source answer to commercial enterprise web scanners.
Wifite2	8.3k	2015	2026-08-05 ✅	— Automated wireless auditor that simplifies attacking WEP, WPA and WPS networks with minimal user interaction. Used by penetration testers and wireless auditors; a popular automation wrapper. (GPL-2.0)
aircrack-ng	7.9k	2018	2026-10-09 ✅	— the complete WiFi security audit suite: capture, inject and audit — the wireless standard for two decades. Used by WiFi security auditors worldwide; the complete free suite replacing any commercial WiFi assessment tool. (GPL-2.0)
MITRE Caldera	7.5k	2017	2026-10-12 ✅	— scalable adversary-emulation platform built on ATT&CK; run purple-team exercises that prove your detections actually fire. Used by red teams and purple teams for automated adversary emulation; the open-source alternative to commercial breach-attack-simulation platforms like AttackIQ and SafeBreach.
RsaCtfTool	7.2k	2015	2026-10-23 ✅	— RSA security-testing tool: attacks weak keys and unprotected disclosures purely offline, for auditors and CTF practice. Used by CTF players and crypto researchers attacking weak RSA keys; a niche free tool with no commercial counterpart. (GPL-3.0)
WhatWeb	7k	2010	2026-04-02 ✅	— identifies what a website is built with — frameworks, CMSs, servers and versions — in one command. Used by recon teams to fingerprint what a site runs on; the standard free tech-identifier behind many commercial recon feeds. (GPL-2.0)
Responder	6.7k	2016	2026-06-10 ✅	— LLMNR/NBT-NS/MDNS poisoner; the fastest way to demonstrate credential-leak exposure on an authorized internal network. Used by internal penetration testers to demonstrate credential exposure on enterprise networks; the canonical LLMNR/NBT-NS poisoner. (GPL-3.0)
osmedeus	6.7k	2018	2026-11-06 ✅	— workflow engine that chains recon and scanning into scheduled, repeatable attack-surface pipelines. Used by recon teams automating full attack-surface workflows; the free alternative to commercial ASM platforms for scheduled recon.
wafw00f	6.6k	2014	2026-04-19 ✅	— fingerprints the web application firewall sitting in front of a site so you know exactly what you're testing against. Used by pentesters planning engagements to fingerprint WAFs first; the standard free WAF detector.
APKLeaks	6.4k	2020	2025-08-20 ⏳	— Scans APK files for URIs, endpoints, and hardcoded secrets, quickly extracting API keys and internal URLs from compiled Android apps. Used by mobile pentesters and bug bounty hunters; a fast secrets-hunting utility. (Apache-2.0)
NetExec	6k	2023	2026-11-11 ✅	— CrackMapExec's actively maintained successor; audit credential hygiene and service misconfigurations across whole subnets. Used by internal network auditors and AD pentesters for credential-hygiene sweeps.

Fluxion	6k	2017	2026-11-06 ✅	— Social-engineering focused Wi-Fi attack tool that creates rogue access points and captive portals to harvest credentials. Used by penetration testers; a popular rogue AP framework. (GPL-3.0)
commix	5.9k	2015	2026-11-12 ✅	— automated OS command injection detection and exploitation for web tests. Used by web pentesters for command-injection proof; a focused free tool that complements general-purpose commercial scanners. (GPL-3.0)
Merlin	5.6k	2017	2026-10-15 ✅	— Post-exploitation command-and-control server using HTTP/2 for covert channels. Used by red teams and penetration testers; an offensive C2 framework. (GPL-3.0)
Dalfox	5.4k	2020	2026-11-11 ✅	— fast XSS scanner with DOM-aware analysis and a strong payload set; the modern XSS go-to. Used by bug bounty hunters for fast, DOM-aware XSS scanning; a favorite free alternative to Burp's scanner for XSS-only sweeps.
Empire	5.3k	2019	2026-09-08 ✅	— Post-exploitation framework for PowerShell agents with modular capabilities. Used by red teams and penetration testers; a well-known offensive C2 platform. (BSD-3-Clause)
CamPhish	5.3k	2020	2025-04-29 ⏳	— Webcam phishing attack tool that captures images via a crafted link. Used by penetration testers and security educators; a popular social-engineering demonstration utility. (GPL-3.0)
Windows Exploit Suggester	5k	2019	2026-11-06 ✅	— Suggests exploits based on Windows OS versions and patch levels. Used by penetration testers and red teams; a practical offensive reconnaissance utility. (BSD-3-Clause)
OpenVAS Scanner	4.9k	2018	2026-11-11 ✅	— Greenbone's open-source vulnerability scanning engine for network and service flaws. Used by security teams running unauthenticated network vulnerability scans; the classic open-source alternative to Nessus, Qualys and Rapid7 InsightVM. (GPL-2.0)
SocialFish	4.9k	2018	2026-05-20 ✅	— Social-engineering phishing framework for credential harvesting and campaign management. Used by red teams and awareness trainers; a well-known offensive security project. (BSD-3-Clause)
Mythic	4.9k	2018	2026-11-06 ✅	— Collaborative cross-platform C2 framework with plug-and-play architecture for payload types and communication profiles. Used by red teams and purple teamers; a flexible open-source command-and-control platform. (NOASSERTION)
CDK	4.8k	2020	2026-05-01 ✅	— Zero-dependency container penetration toolkit for stable exploitation in slimmed containers without OS dependencies. Used by container pentesters; a compact free exploitation toolkit. (Apache-2.0)
Donut	4.8k	2019	2025-07-08 ⏳	— Position-independent shellcode generator and in-memory payload injector that converts executables, .NET assemblies, and scripts into encrypted shellcode. Used by red teamers and malware researchers; a widely adopted payload conversion utility. (BSD-3-Clause)
Covenant	4.8k	2019	2024-07-18 ⏳	— C#-based post-exploitation platform for red team operations. Used by red teams and penetration testers; a modern offensive C2 framework. (GPL-3.0)
Drozer	4.7k	2012	2026-04-08 ✅	— Security assessment framework for Android focused on exploiting inter-process communication surfaces. Used by mobile pentesters; a leading tool for Android IPC testing. (NOASSERTION)
ROPgadget	4.5k	2011	2026-06-24 ✅	— Searches binaries for ROP gadgets across ELF, PE, and Mach-O formats. Used by exploit developers and CTF players; a standard binary-exploitation utility.
afrog	4.5k	2022	2026-11-10 ✅	— fast cross-platform vulnerability scanner driven by a 1,700+ community-maintained YAML PoC corpus covering CVE, CNVD, unauthorized-access, default-password and fingerprinting checks. Used by bug bounty hunters and pentesters running corpus-driven scans; the open-source scanner with one of the largest community PoC collections. (MIT)
GitTools	4.2k	2015	2026-09-29 ✅	— recovers an exposed `.git` directory into full source and commit history — audit your servers before attackers do. Used by bug bounty hunters to recover exposed .git directories into full source; the go-to free tool for this bug class.
tplmap	4.2k	2016	2024-04-21 ⏳	— Detection and exploitation tool for code and server-side template injection vulnerabilities. Used by pentesters and bug-bounty hunters; a leading SSTI exploitation framework. (GPL-3.0)
Ghauri	4.1k	2022	2025-10-04 ⏳	— a strong sqlmap alternative for error/union/blind SQLi with clever parameter tampering; slower release cadence but unique value. Used by bug bounty hunters for tricky blind, error-based and time-based SQLi.

Patator	3.9k	2014	2026-11-07 ✅	— Multi-purpose brute-forcing tool supporting numerous protocols for credential testing. Used by penetration testers; a versatile free brute-force framework. (GPL-2.0)
Wifite	3.7k	2012	2022-09-08 ⏳	— Automated wireless attack tool that streamlines Wi-Fi auditing workflows. Used by penetration testers; a popular free scripted wireless testing tool.
BloodHound	3.6k	2023	2026-11-11 ✅	— maps the shortest attack paths through Active Directory; defenders run it to find and fix their way to Domain Admin. Used by Active Directory pentesters to map hidden attack paths; the standard tool defenders also run to harden AD.
Weevely	3.5k	2014	2025-10-01 ⏳	— Weaponized web shell providing a stealthy backdoor and post-exploitation modules over HTTP. Used by pentesters and red teamers; a modular webshell framework. (GPL-3.0)
awesome-cve-poc	3.5k	2017	2022-01-04 ⏳	— Curated list of CVE proof-of-concept exploits maintained on GitHub. Used by pentesters and vulnerability researchers; a broad PoC discovery index.
Nmap Vulners	3.5k	2017	2026-11-02 ✅	— Nmap NSE script that queries the Vulners database to detect CVEs for discovered services. Used by pentesters and network auditors; a handy way to enrich Nmap scans with vulnerability data. (NOASSERTION)
fuzz.txt	3.4k	2016	2026-07-28 ✅	— Wordlist of potentially dangerous files for web fuzzing and content discovery. Used by pentesters and bug-bounty hunters; a handy payload list for finding exposed sensitive paths. (WTFPL)
NoSQLMap	3.4k	2013	2026-10-13 ✅	— the classic NoSQL injection and enumeration tool for MongoDB, CouchDB and Redis-backed apps in authorized tests. Used by pentesters attacking NoSQL-backed endpoints when SQLi tooling does not apply; the reference NoSQL injection toolkit since 2013. (GPL-3.0)
kiterunner	3.3k	2021	2026-07-10 ✅	— API route brute-forcer with method-aware wordlists derived from Swagger specs; dormant upstream, still the reference. Used by API security testers brute-forcing routes with method-aware wordlists; the open-source alternative to commercial API discovery scans. (AGPL-3.0)
AdvPhishing	3.3k	2019	2026-01-05 ✅	— Advanced phishing tool with login page cloning and tunneling support. Used by penetration testers and security researchers; an offensive social-engineering framework.
CSS-Keylogging	3.2k	2018	2018-02-20 ⏳	— Chrome extension and Express server demonstrating keylogging via CSS injection techniques. Used by security researchers and pentesters; an educational CSS exfiltration proof of concept.
plasma	3.1k	2015	2021-08-31 ⏳	— Interactive disassembler for x86, ARM, and MIPS architectures. Used by reverse engineers; a retargetable binary analysis and disassembly framework. (GPL-3.0)
ettercap	2.8k	2012	2026-11-10 ✅	— the veteran MITM analysis suite for ARP poisoning, sniffing and protocol dissection — bettercap's classic sibling. Used by network pentesters and students learning MITM analysis; the veteran suite that inspired later tools like Bettercap. (GPL-2.0)
Slowloris	2.8k	2015	2024-06-01 ⏳	— HTTP DoS tool that keeps many connections open to exhaust server resources. Used by penetration testers and red teams; a classic low-bandwidth denial-of-service proof of concept. (MIT)
blutter	2.8k	2023	2026-08-18 ✅	— Reverse engineering tool that extracts Dart code and function signatures from Flutter snapshot files. Used by mobile reverse engineers; a focused free Flutter analysis utility. (MIT)
Astra	2.7k	2018	2024-06-05 ⏳	— Automated security testing tool for REST APIs from Flipkart, checking endpoints for common API vulnerabilities. Used by API developers and pentesters; a solid open-source API scanner. (Apache-2.0)
brutespray	2.6k	2017	2026-11-12 ✅	— multi-protocol credential brute-forcer that parses Nmap and Nessus output and sprays discovered services, on networks you are authorized to test. Used by pentesters validating default and weak credentials; the classic Python companion to Hydra. (MIT)
EAPHammer	2.6k	2017	2024-09-22 ⏳	— Targeted evil twin attacks against WPA2-Enterprise networks, supporting hostile portal and credential capture. Used by red teamers and wireless testers; a focused enterprise Wi-Fi attack tool. (GPL-3.0)
PhpSploit	2.5k	2014	2024-05-06 ⏳	— Full-featured C2 framework that silently persists on a webserver via an evil PHP oneliner. Used by red teamers; a stealthy web-based command-and-control tool. (GPL-3.0)

Some-PoC-oR-ExP	2.5k	2015	2025-06-24 ⏳	— Chinese-language collection of vulnerability PoCs and exploits. Used by security researchers; a broad exploit code repository.
hcxtools	2.5k	2017	2026-10-31 ✅	— Converts packet captures into hash files for cracking with Hashcat or John the Ripper. Used by wireless auditors; essential for modern WPA/WPA2 auditing workflows. (MIT)
one_gadget	2.4k	2017	2026-11-02 ✅	— Finds magic gadgets in libc that spawn a shell with minimal constraints. Used by CTF players and exploit developers; a handy binary-exploitation utility. (MIT)
ezXSS	2.4k	2017	2026-11-05 ✅	— self-hosted blind XSS platform: payload links, session capture (DOM, cookies, screenshots) and instant alerts when a stored payload fires. Used by bug bounty hunters proving blind XSS in admin panels; the standard self-hosted XSS callback manager. (MIT)
js-vuln-db	2.3k	2016	2019-09-03 ⏳	— Collection of JavaScript engine CVEs with accompanying proof-of-concept code. Used by browser exploit developers; a focused JS engine PoC database.
f8x	2.2k	2021	2026-10-16 ✅	— red/blue team environment automation: deploys a full security-tool stack on a fresh Linux host in a few commands. Used by teams standing up engagement or lab boxes fast; a community standard for toolbox provisioning. (Apache-2.0)
hcxdumptool	2.2k	2018	2026-10-25 ✅	— Small tool for capturing packets from WLAN devices, specifically designed for PMKID and handshake collection for Hashcat. Used by wireless auditors; a modern capture utility. (MIT)
xssor2	2.2k	2017	2021-12-12 ⏳	— XSS exploitation toolkit that lets testers hack with JavaScript payloads in browser contexts. Used by web pentesters and bug-bounty hunters; a classic XSS research utility. (BSD-2-Clause)
ropper	2.2k	2014	2026-08-22 ✅	— Finds and displays ROP gadgets for building chains across multiple architectures. Used by exploit developers and security researchers; a popular binary-exploitation tool. (BSD-3-Clause)
PEzor	2.1k	2020	2024-02-03 ⏳	— Open-source packer for executable files designed to evade antivirus detection through obfuscation and encryption. Used by red teamers and malware analysts; a straightforward PE packing utility. (GPL-3.0)
HTTPLeaks	2.1k	2015	2026-09-09 ✅	— Reference listing all possible ways a website can leak HTTP requests to external destinations. Used by web security researchers; an educational leak-vector catalogue. (BSD-2-Clause)
reverse-shell	2.1k	2017	2026-02-18 ✅	— Reverse shell as a service that generates one-liner payloads for establishing reverse shells on target hosts. Used by pentesters and red teamers; a convenient payload generator. (MIT)
SysWhispers	2k	2019	2023-01-01 ⏳	— Syscall generator for evasion, enabling direct system calls to bypass user-mode hooks placed by EDR solutions. Used by red teamers and malware researchers; a foundational direct-syscall tool. (Apache-2.0)
Reaver	2k	2015	2025-10-31 ⏳	— Implements a brute-force attack against Wi-Fi Protected Setup registrar PINs to recover WPA/WPA2 passphrases. Used by wireless penetration testers; a classic WPS attack tool.
Ghostwriter	2k	2019	2026-11-06 ✅	— Reporting and engagement management platform for offensive security teams. Used by red teams and pentesters; a structured way to track engagements and deliver findings. (BSD-3-Clause)
wapiti	1.9k	2020	2026-11-10 ✅	— open-source black-box web vulnerability scanner that crawls and audits without needing a browser. Used by web pentesters and CI pipelines for black-box web scanning; a solid free alternative to paid web vulnerability scanners. (GPL-2.0)
RSMangler	1.9k	2017	2024-12-10 ⏳	— Hash brute-force tool for creating password dictionaries and mangling wordlists. Used by penetration testers; a lightweight free wordlist generator. (MIT)
SharpSploit	1.9k	2018	2021-08-12 ⏳	— .NET post-exploitation library written in C# that highlights the attack surface of .NET and simplifies offensive operations. Used by red teamers; a well-known reference for .NET tradecraft. (BSD-3-Clause)
libc-database	1.9k	2015	2026-10-24 ✅	— Builds a database of libc offsets to identify libc versions from leaked addresses. Used by exploit developers and CTF players; a practical binary-exploitation helper. (MIT)

InQL	1.8k	2018	2026-11-10 ✅	— the reference GraphQL security testing toolkit as a Burp Suite extension: schema introspection analysis, query generation, vulnerability scanning and engine fingerprinting. Used by pentesters auditing GraphQL APIs where classic proxies stop at the surface; doyensec-maintained since 2018. (Apache-2.0)
Inceptor	1.8k	2021	2023-11-03 ⏳	— Template-driven framework for AV and EDR evasion, providing modular templates for payload generation and obfuscation. Used by red teamers; a flexible evasion template engine. (NOASSERTION)
dvcs-ripper	1.8k	2012	2024-07-19 ⏳	— Rips web-accessible distributed version control repositories such as SVN, Git and Mercurial. Used by pentesters and bug-bounty hunters; a reliable source-code exposure extractor. (GPL-2.0)
Pixiewps	1.8k	2015	2026-10-28 ✅	— Offline WPS PIN brute-force utility exploiting low entropy in vulnerable implementations via the Pixie Dust attack. Used by wireless auditors; a fast offline WPS attack tool. (NOASSERTION)
gotestwaf	1.8k	2020	2026-10-28 ✅	— WAF assessment harness: fires ~900 benign-and-attack test cases (OWASP, fauxpas, shadowd) at a protected path and grades what the WAF actually blocks, with a hardening report. Used by pentesters measuring WAF effectiveness before tuning payloads; the Wallarm WAF benchmark. (MIT)
graudit	1.7k	2009	2026-10-13 ✅	— grep-based rough source-code auditor: one shell script + 26 regex signature databases (php, sql, xss, secrets, java, python…) for first-pass static review. Used by auditors triaging unfamiliar codebases before deep review; 17 years maintained, v4.1 (2026). (GPL-3.0)
ctftool	1.7k	2019	2021-09-17 ⏳	— Interactive CTF exploration tool for Windows environments. Used by red teamers and CTF players; an offensive exploration and exploitation utility. (Apache-2.0)
Akto	1.5k	2023	2026-11-12 ✅	— self-hosted API-security platform that builds a continuous API inventory from mirrored runtime traffic and runs business-logic tests (BOLA, BFLA, OWASP API Top 10) in CI. Used by API security teams testing business-logic flaws generic DAST misses; the open-source alternative to API-scanning SaaS. (MIT)
Iaitō	1.5k	2017	2021-04-07 ⏳	— Qt and C++ GUI for the radare2 reverse engineering framework. Used by malware analysts and reverse engineers; a graphical disassembly and analysis frontend. (GPL-3.0)
Grapefruit	1.4k	2020	2026-10-28 ✅	— Open-source runtime mobile instrumentation toolkit powered by Frida with a web interface for inspecting, hooking, and modifying iOS and Android apps. Used by mobile security researchers; a practical dynamic analysis workbench. (MIT)
CredSniper	1.4k	2017	2020-05-22 ⏳	— Phishing framework with two-factor authentication bypass support for credential capture. Used by red teams and security researchers; an advanced offensive social-engineering tool. (Apache-2.0)
Artemis	1.3k	2022	2026-11-11 ✅	— modular web-vulnerability scanning platform that powers CERT Poland's nation-scale scanning (50.6k domains since 2023) and auto-generates human-readable, FP-filtered advisory reports per organization. Used by CSIRTs running continuous constituency scanning with e-mailable advisories; the public blueprint for national-scale detection. (BSD-3-Clause)
Singularity of Origin	1.3k	2018	2026-07-21 ✅	— DNS rebinding attack framework that rebinds the attack server's DNS name to the target machine's IP and serves payloads. Used by security researchers; a ready-made rebinding platform. (MIT)
XSRFProbe	1.3k	2018	2026-07-12 ✅	— CSRF audit and exploitation toolkit that scans applications for cross-site request forgery weaknesses. Used by web pentesters and bug-bounty hunters; a dedicated CSRF testing suite. (GPL-3.0)
Shhhloader	1.3k	2021	2024-05-08 ⏳	— Shellcode loader that compiles a C++ stub performing multiple AV/EDR bypass techniques, with a Python builder for Linux-based cross-compilation. Used by red teamers; a convenient loader-generation workflow. (GPL-3.0)
FlowDroid	1.3k	2018	2026-11-11 ✅	— Precise context, flow, field, and object-sensitive taint analysis framework for Android apps, detecting data leakage and injection vulnerabilities. Used by mobile security researchers; a rigorous static analysis engine. (LGPL-2.1)
hermes-dec	1.2k	2022	2026-10-15 ✅	— Decompiler for Hermes bytecode used in React Native apps, converting bytecode back to readable JavaScript. Used by mobile reverse engineers; a niche free analysis tool. (AGPL-3.0)
aws_pwn	1.2k	2016	2023-08-30 ⏳	— Collection of AWS penetration testing scripts and utilities for assessing cloud account security. Used by cloud pentesters and red teamers; a practical AWS attack toolkit.

Flashrom	1.2k	2011	2026-11-10 ✅	— Utility for detecting, reading, writing, verifying, and erasing flash chips via SPI programmers. Used by firmware analysts; the standard open-source flash tool. (GPL-2.0)
Cmsmap	1.2k	2018	2021-12-01 ⏳	— CMS detection and exploitation tool that fingerprints content management systems and probes for known issues. Used by web pentesters; a practical CMS-focused scanner. (GPL-3.0)
Pywerview	1.2k	2016	2026-04-21 ✅	— a Python port of PowerView's AD recon verbs; same questions, no Windows host required. Used by AD pentesters who live on Linux but need PowerView-style Windows enumeration; the Python port of the classic PowerView. (GPL-3.0)
jwt-hack	1.1k	2020	2026-11-08 ✅	— JWT attack toolkit: cracking, payload generation, alg-confusion and claim-abuse checks for JSON Web Tokens in one CLI. Used by bug bounty hunters and pentesters auditing token-based authentication; the dedicated free toolkit for the JWT bug class.. (MIT)
Vigolium	1.1k	2026	2026-10-25 ✅	— High-fidelity vulnerability scanner fusing agentic AI with native speed, modularity and precision. Used by security researchers and pentesters; a modern scanning engine from a known author.
GadgetToJScript	1.1k	2019	2021-07-26 ⏳	— Generates .NET serialized gadgets that trigger assembly load and execution when deserialized from JS/VBS/VBA scripts, enabling fileless execution. Used by red teamers; a known tradecraft utility for script-based payload delivery. (GPL-3.0)
ProtectMyTooling	1.1k	2021	2025-10-14 ⏳	— Multi-packer wrapper that daisy-chains various packers and obfuscators with artifact watermarking and IOC collection. Used by red teamers; a convenient orchestration layer for evasion tooling. (MIT)
Proxelar	1.1k	2023	2026-11-06 ✅	— Single-binary intercepting proxy for HTTP, HTTPS, and WebSocket traffic that pauses and edits requests in flight, replays them, and rewrites traffic. Used by pentesters; a lightweight interception tool. (MIT)
Wakaru	1.1k	2023	2026-11-08 ✅	— JavaScript decompiler that splits production bundles from webpack, esbuild, Browserify, and Metro into modules and de-minifies code. Used by analysts; a bundle reconstruction tool. (Apache-2.0)
goshs	1k	2020	2026-11-09 ✅	— hardened HTTP file-transfer server built for engagements: upload/download, authentication, access control and TLS — the modern replacement for `python -m http.server`. Used by pentesters on engagements as a hardened file-transfer server; the security-hardened alternative to spinning up ad-hoc Python servers.
BYOVD Research	1k	2023	2026-08-18 ✅	— Bring Your Own Vulnerable Driver research repository with detection and reverse engineering methodology covering recent CVEs. Used by red teamers and defenders; a practical reference for BYOVD attack and detection. (GPL-3.0)
Fuzzbunch	999	2017	2017-04-17 ⏳	— NSA exploit framework leaked as part of the Shadow Brokers dump. Used by researchers and red teams; a historically significant offensive exploitation toolkit.
Coldfire	987	2020	2024-12-13 ⏳	— Golang malware development library providing functions for process manipulation, network operations, privilege checking, and evasion. Used by red teamers and malware researchers; a convenient Go toolkit for offensive implants. (MIT)
Charlotte	973	2021	2021-06-11 ⏳	— C++ shellcode launcher designed to bypass security monitoring without triggering alerts. Used by red teamers; a compact loader for evasion testing.
Caring Caribou	972	2015	2026-06-12 ✅	— Zero-knowledge CAN bus exploration tool that discovers services, dumps traffic, and fuzzes messages. Used by automotive pentesters; a popular discovery utility. (GPL-3.0)
Phishing Frenzy	901	2013	2023-11-07 ⏳	— Phishing campaign automation platform for running simulated social engineering engagements. Used by red teams; a free phishing simulation framework. (GPL-3.0)
DarkArmour	893	2020	2020-04-13 ⏳	— Windows antivirus evasion tool that stores and executes an encrypted Windows binary entirely from memory without writing to disk. Used by red teamers; a compact in-memory execution utility. (MIT)
h5i	915	2026	2026-11-12 ✅	— agent-native web-security workspace: deterministic recon, secrets scanning, DOM post-message auditing and CI regression checks — fully usable without any LLM key. Used by security engineers wanting agent-native, deterministic web checks; a newer open alternative to dashboard-driven commercial scanners. (Apache-2.0)

KillerBee	852	2015	2023-09-12 ⏳	— Zigbee security testing framework for capturing traffic, testing replay attacks, and checking key exchange security. Used by wireless pentesters; a classic Zigbee toolkit. (GPL-3.0)
Obfusk8	843	2025	2026-06-25 ✅	— Lightweight C++17 header-only obfuscation library for Windows binaries, providing compile-time obfuscation capabilities. Used by red team developers; an easy-to-integrate obfuscation building block. (MIT)
Killer	842	2023	2024-07-02 ⏳	— Simple tool designed to bypass AV/EDR security tools using various evasion techniques. Used by red teamers; a lightweight evasion utility for quick testing.
Prism X	834	2023	2026-10-26 ✅	— automated enterprise network security risk detection in the AWVS/fscan class. Used by internal teams risk-scoring their own networks; the free enterprise-web risk scanner. (Apache-2.0)
numasec	836	2026	2026-05-08 ✅	— AI-driven penetration-testing platform coordinating 10 agents and 38 vulnerability scanners across the OWASP Top 10. Used by pentesters and security teams; an ambitious autonomous testing framework. (AGPL-3.0)
JTAGulator	823	2013	2026-09-02 ✅	— Open-source hardware tool that brute-forces pins to discover JTAG and UART assignments on unknown boards. Used by hardware hackers; a staple of PCB reverse engineering.
MDK4	819	2018	2026-05-29 ✅	— Wi-Fi testing tool designed to exploit common protocol weaknesses, including deauthentication and beacon flooding. Used by wireless auditors; a staple for protocol stress testing. (GPL-3.0)
DarkWidow	817	2023	2026-01-26 ✅	— Advanced malware payload framework using indirect dynamic syscalls, SSN sorting via modified TartarusGate, and APC-based remote process injection. Used by red teamers and malware researchers; a sophisticated evasion-focused offensive toolkit. (MIT)
JTAGenum	806	2010	2023-10-30 ⏳	— Arduino-compatible JTAG pin scanning tool that enumerates instruction registers and discovers undocumented instructions. Used by hardware hackers; a handy open-source enumerator. (GPL-3.0)
OpenTRAP	703	2026	2026-11-08 ✅	— Free open-source Burp Suite alternative: an intercepting proxy with Repeater, Intruder, a Collaborator-style OAST server and the built-in OWASP ZAP scanner in one desktop suite. Used by web pentesters who want a full proxy workbench without a license; the open alternative built on the ZAP engine.. (AGPL-3.0)
Katana Framework	715	2015	2021-04-05 ⏳	— Post-exploitation and reporting utility framework for penetration testing. Used by pentesters; a tool for managing exploitation activity and output.
uxss-db	707	2017	2021-01-23 ⏳	— Collection of UXSS CVEs with proof-of-concept code. Used by browser security researchers; a focused universal XSS PoC database. (MIT)
5G Houl	703	2023	2026-03-11 ✅	— Fuzzing tool that discovers vulnerabilities in 5G NR implementations, misleading UEs into connecting to malicious base stations. Used by telecom security researchers; a notable 5G NR fuzzer. (GPL-2.0)
dtd-finder	664	2019	2024-02-21 ⏳	— Lists local DTDs and generates XXE payloads using them for XML external entity testing. Used by web pentesters; a focused XXE payload helper.
Whonow DNS Server	659	2018	2021-12-17 ⏳	— Malicious DNS server for executing DNS rebinding attacks on the fly. Used by pentesters and researchers; a flexible rebinding attack server. (MIT)
Realm	647	2022	2026-11-11 ✅	— open-source adversary-emulation framework with cross-platform implants and Terraform-driven C2 infrastructure for authorized red teams. Used by red teams running repeatable, scoped adversary emulation; the open-source alternative to commercial adversary-simulation platforms. (GPL-3.0)
OXO	585	2021	2026-11-11 ✅	— pip-installable security-scanning orchestrator that composes Docker-image agents (nmap, nuclei, ZAP, subfinder…) into typed asset scan graphs with a CLI + GraphQL API. Used by security engineers chaining multi-tool pipelines without glue code; scans IPs, domains, links, files and mobile apps. (Apache-2.0)
bXSS	581	2017	2023-03-04 ⏳	— Simple blind XSS application adapted from cure53 research for testing out-of-band payload execution. Used by web pentesters; a lightweight blind XSS harness. (MIT)
Armitage	575	2015	2021-11-10 ⏳	— GUI front-end for Metasploit that visualizes attacks and targets. Used by penetration testers and red teams; a well-known offensive collaboration tool. (BSD-3-Clause)
Bully	578	2016	2023-10-10 ⏳	— WPS attack tool that brute-forces wireless PINs. Used by penetration testers; a focused free utility for WPS security testing. (GPL-3.0)

JShell	532	2018	2019-05-05 ⏳	— Tool that obtains a JavaScript shell through XSS, enabling interactive exploitation in the victim browser. Used by web pentesters and bug-bounty hunters; a clever XSS post-exploitation helper.
DNS Rebind Toolkit	506	2018	2021-10-02 ⏳	— Frontend JavaScript framework for developing DNS rebinding exploits against vulnerable hosts and services on a local network. Used by pentesters; an exploit development toolkit. (MIT)
UnlockECU	461	2020	2026-06-04 ✅	— Open-source ECU seed-key unlocking tool that bypasses security access mechanisms for diagnostic work. Used by automotive researchers; a practical unlock utility. (MIT)
nano	448	2018	2020-02-18 ⏳	— Family of code-golfed PHP shells designed to be tiny and evasive. Used by red teamers; a minimal webshell collection for constrained payloads.
authz0	429	2022	2026-10-14 ✅	— CLI broken-access-control tester that replays the same URL set under multiple roles' credentials from a YAML template and flags unauthorized responses. Used by pentesters proving BOLA/authz gaps in minutes instead of hours; role-pair replay made repeatable. (MIT)
Webshell-Sniper	427	2017	2026-10-26 ✅	— Terminal tool to manage a compromised website via webshell interaction. Used by penetration testers; a post-exploitation webshell management utility. (GPL-3.0)
SigPloit	406	2017	2019-12-17 ⏳	— Telecom signaling exploitation framework covering SS7, GTP, Diameter and SIP protocols for testing mobile operator interconnects. Used by telecom security researchers; a multi-protocol signaling testbed. (MIT)
ScareCrow	386	2023	2023-07-20 ⏳	— Payload toolkit using suspended processes and direct syscalls for EDR evasion, generating loaders that execute payloads without touching disk. Used by red teamers; a popular loader generator for evasion testing.
Vega	362	2010	2021-02-23 ⏳	— GUI-based web vulnerability scanner for crawling sites and probing for common injection and misconfiguration flaws. Used by web pentesters and security testers; a graphical scanner for interactive assessments. (GPL-2.0)
DVCS-Pillage	331	2011	2017-01-19 ⏳	— Tool to pillage web-accessible Git, Mercurial and Bazaar repositories for source code recovery. Used by pentesters and bug-bounty hunters; a handy VCS exposure exploitation utility.
CANToolz	318	2016	2017-10-31 ⏳	— Modular CAN bus analysis framework chaining modules for ECU discovery, man-in-the-middle testing, fuzzing, and brute-forcing. Used by automotive researchers; a flexible CAN toolkit. (GPL-3.0)
Nightingale	319	2020	2026-11-08 ✅	— dockerized pentest environment preconfigured with the essential VAPT toolset. Used by pentesters and training labs that want a reproducible toolbox; the Docker alternative to hand-built pentest VMs. (GPL-3.0)
Pithus	302	2020	2026-11-11 ✅	— Open-source APK analyzer with YARA rule hunting for malware detection and threat intelligence on Android apps. Used by mobile malware analysts; a capable free static analysis platform. (AGPL-3.0)
TLS-Scanner	285	2017	2026-11-07 ✅	— Open-source tool for analyzing TLS configurations in 5G core networks, checking for padding oracle, Bleichenbacher and POODLE vulnerabilities. Used by telecom security testers; a specialized TLS scanner. (Apache-2.0)
crossfyre-toolchain	258	2025	2026-11-11 ✅	— Recon-to-scan toolchain of five Rust engines — subdomain discovery, port scanning, content fuzzing, fingerprinting and vulnerability checks — plus a self-hosted OAST server that confirms each finding before it reports it. Used by bug bounty hunters running fast terminal-first pipelines; the Rust-native alternative to stitched-together shell toolkits.. (Apache-2.0)
pphack	247	2024	2026-11-10 ✅	— advanced client-side prototype-pollution scanner for JavaScript-heavy web apps. Used by bug bounty hunters auditing front-end pollution sinks; the dedicated free scanner for this bug class. (MIT)
Reverse-Shell-Manager	247	2017	2023-07-05 ⏳	— Terminal-based manager for handling multiple reverse shell sessions during engagements. Used by penetration testers; a session management utility for offensive work.
graphinder	228	2022	2026-11-05 ✅	— GraphQL endpoint discovery: expands domains from CT logs and certificate SANs, then probes permutations with a wordlist to find unlisted GraphQL endpoints. Used by bug bounty hunters hunting hidden GraphQL surfaces; Escape Technologies' clean dockerized finder. (MIT)
cefdebug	210	2019	2020-06-10 ⏳	— Minimal code to connect to a Chrome Embedded Framework debugger for exploitation research. Used by security researchers; a focused CEF debugging utility. (Apache-2.0)

jiraffe	205	2020	2026-04-02 ✅	— Jira recon and security auditing: version fingerprinting, gadget/permission checks and CVE mapping for authorized instances. Used by bug bounty hunters targeting Atlassian deployments; a focused free exploitation kit for the Jira bug class. (MIT)
ARS3NAL	192	2026	2026-07-09 ✅	— Offline-first self-hosted pentest and bug-bounty arsenal with searchable payloads, command generator, GTFOBins and wordlists. Used by pentesters and bug-bounty hunters; a convenient all-in-one reference. (GPL-3.0)
SocialBox	146	2020	2023-07-14 ⏳	— Brute-force social media hacking toolkit targeting multiple platforms. Used by penetration testers and security students; an offensive credential-testing utility. (MIT)
Cyclops is a novel browser that ca...	127	2022	2024-06-30 ⏳	— Chromium-based browser with XSS taint tracking to detect vulnerabilities automatically. Used by web security researchers; a novel offensive analysis tool. (GPL-3.0)
unKover	127	2026	2026-10-13 ✅	— the 403 access-bypass tester: a 13-technique battery (path rewrites, header tricks, HTTP method and version shifts) that turns forbidden endpoints into authorized access. Used by web pentesters proving 403s are misconfigurations during engagements; the focused free alternative to commercial authz-testing modules. (MIT per README)
pwngitmanager	109	2016	2016-06-04 ⏳	— Git repository manager tailored for pentesters to organize and track engagement code and notes. Used by pentesters and red teamers; a practical workflow helper.
Rodan	109	2021	2025-12-01 ⏳	— Telecom signaling exploitation framework with SS7 and Diameter support, featuring location tracking and call/SMS interception. Used by telecom researchers; a comprehensive signaling attack suite. (AGPL-3.0)
5Greplay	104	2021	2026-03-31 ✅	— NGAP fuzzing tool used for testing 5G core network AMF implementations across Open5GS, free5GC, OAI and ella-core. Used by telecom security researchers; a focused 5G core fuzzer. (Apache-2.0)
PWN	86	2022	2026-11-09 ✅	— Ruby offensive-security automation framework that orchestrates Burp, Nessus, OpenVAS, ZAP and other engines into scripted authorized engagements. Used by pentesters chaining commercial and open engines from one Ruby CLI; the glue layer for multi-engine engagements. (MIT)
asnfuzzgen	53	2024	2024-08-27 ⏳	— ASN.1-based fuzzing tool for the Radio Resource Control protocol in 4G and 5G networks, generating syntactically correct payloads. Used by telecom security researchers; a specialized RRC fuzzer. (MIT)
BugBoard	53	2024	2026-06-23 ✅	— Bug hunter dashboard for vulnerability scanning, automation, and managing bug bounty workflows. Used by bug bounty hunters; a workflow hub for organizing recon and findings. (MIT)
Nullock	42	2026	2026-09-30 ✅	— zero-telemetry HTTP/2 and WebSocket-native Burp alternative with a plugin ecosystem. Used by privacy-conscious web testers; the telemetry-free Burp alternative. (MIT)
rcekit	28	2025	2026-11-10 ✅	— zero-dependency RCE confirmation toolkit with false-positive-resistant sink tiering. Used by pentesters confirming command-injection findings safely; the confirmation tier for injection testing. (MIT)
wafrift	25	2026	2026-11-14 ✅	— programmable WAF-evasion engine: evolutionary search caches bypass combos in per-WAF gene banks that warm-start later scans; 4-axis WAF/CDN/origin fingerprinting, 230 auth-bypass header probes and a nightly verified-bypass scoreboard. Used by pentesters measuring and defeating WAF stacks on authorized targets; the gene-bank take on WAF bypass. (Apache-2.0 OR MIT)
Hakscan	19	2026	2026-10-31 ✅	— Fast, self-contained vulnerability scanner shipped as a single Go binary — covers web apps, APKs and binaries, extensible with JSON and nuclei YAML templates. Used by bug bounty hunters wanting one-binary scanning across target types; the portable free scanner for quick triage.. (MIT)
Sniper	14	2026	2026-11-11 ✅	— fast Rust-native intercepting proxy with passive scanning and AI agent support. Used by web testers wanting a lightweight daily proxy; the Rust alternative for intercepting work. (MIT)
IndustrialXPL-Forge (IXF)	14	2026	2026-10-22 ✅	— Large Python-first OT/ICS/SCADA security assessment and exploitation framework with hundreds of modules spanning dozens of vendors. Used by industrial penetration testers; one of the broadest open exploitation collections for OT. (BSD-3-Clause)

ONUS	12	2026	2026-08-30 ✅	— Web vulnerability assessment platform orchestrating multiple scanners with deterministic CVSS v3.1 scoring and AI-assisted reporting. Used by security teams and pentesters; a consolidated assessment workflow. (MIT)
pentool	10	2026	2026-11-06 ✅	— console-based Burp alternative with crawler, scanner and CI/CD mode. Used by terminal-first pentesters; the TUI web-testing workbench. (AGPL-3.0, copyleft)
WAVSS	10	2025	2026-10-22 ✅	— audit-first web vulnerability scanner for common flaws like SQLi and XSS, with domain-ownership verification, DoS-avoidant pacing and PDF reports with remediation guidance. Used by auditors scanning client sites safely under strict rules of engagement; the audit-focused alternative to exploit-heavy scanners. (no license yet — verify before reuse)
Foojank	9	2024	2026-11-02 ✅	— Open-source C2 framework built on NATS providing customizable transport over TCP and WebSockets. Used by red and purple teams; a modern open-source command-and-control option. (Apache-2.0)
VulnRadar	8	2026	2026-11-11 ✅	— Self-hostable web vulnerability scanner with 855+ deterministic checks, stable finding IDs for scan-to-scan diffing, severity-rated reports and actionable fix guidance. Used by teams wanting instant, shareable scan reports without a SaaS subscription; the self-hosted alternative to commercial web scanners.. (GPL-3.0)
VulnHub Binary Exploitation Repos	8	2025	2026-09-12 ✅	— Curated collection of vulnerable binaries, CVE walkthroughs, and exploitation notes. Used by security students and CTF players; a hands-on binary-exploitation learning repo. (GPL-3.0)
2MNY Website Vulnerability Scan...	5	2026	2026-11-12 ✅	— open-source web vulnerability scanner with 202 deterministic modules: OWASP Top 10, XSS/SQLi/SSRF, subdomain takeover, WordPress and AI/LLM surface checks, CVSS-scored evidence and HTML/PDF reports. Self-hosted via Docker. Used by security teams that want evidence-backed, deterministic scanning they can self-host; the open-source alternative to paid scanner SaaS for website attack surfaces. (maintainer's project)
MNSF	6	2025	2026-04-18 ✅	— Mobile network security framework providing open-source security testing for 2G through 5G networks using SDR and telecom stacks. Used by telecom security researchers; a modular testing framework.
FuzzyDoo	3	2024	2026-01-28 ✅	— Open-source framework for finding flaws in the 5G landscape, enabling dynamic test message generation for encrypted communications. Used by telecom security researchers; a specialized 5G fuzzing framework. (MIT)
UpClaw	3	2026	2026-09-07 ✅	— AI-driven web pentest CLI in a single zero-dependency Python file with 29 built-in checks, 16 tool adapters, and evidence reports. Used by pentesters; a portable offensive testing tool. (Apache-2.0)
perseid	6	2026	2026-11-12 ✅	— memory-bounded Rust Burp alternative with no artificial rate limits. Used by long-running web test sessions; the resource-frugal intercepting proxy. (Apache-2.0)
wp-hunter	2	2026	2026-10-20 ✅	— bilingual WordPress plugin triage toolkit with static authorization analysis, archive integrity checks and version monitoring. Used by WordPress security researchers auditing plugins; the plugin-audit toolkit for WP research. (MIT)
Binary Exploitation Writeups	2	2026	2026-07-22 ✅	— CTF-focused writeups covering buffer overflows, ret2libc, ROP, and shellcode. Used by security students and CTF players; a practical binary-exploitation learning collection.
idoraider	1	2026	2026-10-31 ✅	— Template-driven BOLA/IDOR scanner in Go with dual-token replay: replay the same request under two identities and flag object-level authorization breaks, with zero external dependencies. Used by bug bounty hunters hunting IDOR at scale; the focused free scanner for the BOLA bug class.. (MIT)
Fern WiFi Cracker	1	2021	2021-04-01 ⏳	— Python/Qt-based GUI for wireless security auditing and attack, capable of cracking WEP, WPA and WPS keys. Used by wireless testers and learners; a beginner-friendly GUI auditor.
SWITCHSNIPER	1	2025	2025-08-23 ⏳	— Comprehensive signaling security testing framework for telecom switches and core network systems covering SS7, GTP, Diameter and SIP. Used by telecom security testers; a broad core-network testing suite. (NOASSERTION)
OT/ICS Security Auditor	1	2026	2026-04-26 ✅	— Python-based security assessment toolkit for OT/ICS/SCADA and IoT devices with a GUI and 20+ industrial protocol probes including Modbus. Used by OT assessors; a hands-on auditing utility for industrial environments. (NOASSERTION)
Protofire	1	2025	2025-12-02 ⏳	— Modular OT/ICS protocol fuzzer with plugin support for Modbus/TCP, DNP3, S7comm, IEC 60870-5-104, and OPC UA, plus PCAP replay and anomaly detection. Used by ICS vulnerability researchers; a versatile fuzzing harness for industrial protocols. (MIT)

jwt-auditor	1	2026	2026-07-07 ✅	— Offline CLI that decodes and audits JWTs for alg:none, weak HMAC secrets, and RS256-to-HS256 confusion. Used by pentesters and developers; a focused token-audit utility. (AGPL-3.0)
PathHunter	1	2026	2026-11-14 ✅	— maintained psychoPATH continuation for Burp: path-traversal, LFI and upload-path payload generators with document-root lists, absolute-path and URL-encoding bypass engines, and in-memory multipart upload mutation. Used by web pentesters drilling traversal and upload flaws inside Burp; the actively-developed psychoPATH successor. (GPL-3.0)
SoliTools	0	2026	2026-10-31 ✅	— High-accuracy web security scanner in Go built on the rule that a finding must be worth a human's time — precision beats recall at every decision point. Used by bug bounty hunters who want quiet, high-precision scans; the precision-first free scanner.. (MIT)
sqli-scanner	0	2026	2026-11-13 ✅	— SQL-injection scanner with CLI, web and desktop frontends: ten detectors with WAF identification, SARIF 2.1.0 + CVSS/CWE reports, CI exit codes and an MCP server. Used by teams wiring delivery-grade SQLi detection into CI; the automation-first scanner that complements sqlmap. (MIT)
nemesis	0	2026	2026-11-14 ✅	— differential-experiment scanner: baseline-vs-payload requests report a finding only on measurable behaviour change; 144 modules in 25 groups, default-deny scope, SARIF reports with disclosure drafts, YARA and Sigma emission. Used by pentesters who need findings that survive re-testing; the scanner that proves what it finds. (Apache-2.0)
Pentest-Anything	0	2026	2026-11-14 ✅	— MCP server and CLI orchestrating Semgrep, Nuclei, Trivy and SQLMap behind code-enforced guardrails: scope-before-DNS, metadata and IPv6-embedded-IPv4 blocking, rebinding revalidation, no-shell spawns, redaction; SARIF output and 35+ agent auto-configs. Used by teams letting AI agents run proven scanners without raw shells; the guardrailed agent-to-scanner bridge. (MIT)
BlackEye	0	—	—	— Phishing toolkit that clones login pages for credential harvesting. Used by red teams and social-engineering testers; a popular but ethically sensitive offensive framework.
PyPhisher	0	—	—	— Python-based phishing toolkit with multiple site templates and tunneling options. Used by red teams and security students; a widely used offensive social-engineering tool.
BlueToolkit	0	2025	2025-08-29 ⏳	— Extensible Bluetooth Classic vulnerability testing framework cataloging known automotive Bluetooth exploits. Used by automotive security testers; a focused testing framework. (MIT)
Burp Suite Community Edition	—	—	—	— the industry-standard intercepting proxy for manual web testing; the free tier is where nearly every bug hunter starts. Used by web penetration testers as their daily intercepting proxy; the free tier of the industry-standard Burp Suite Professional. (free, proprietary)
Nmap	—	—	—	— the original network mapper: port, service and OS discovery plus the NSE scripting engine for everything from TLS audits to SMB checks. Used by virtually every network security auditor on earth; the open standard that commercial scanners built their discovery phases on.
PEASS-ng	20.8k	2019	2026-11-09 ✅	— winPEAS/linPEAS privilege-escalation suites; thousands of checks per sweep. (GPL-2.0-or-later)
Evil-WinRM	5.6k	2019	2026-10-16 ✅	— the ultimate WinRM shell with pass-the-hash and LAPS download. (LGPL-3.0)
Ligolo-ng	5.2k	2021	2026-09-26 ✅	— reverse socks5 tunneling; TUN-based pivots. (GPL-3.0)
Rubeus	5.2k	2018	2026-05-21 ✅	— Kerberos toolkit: roast, pass-the-key, diamond tickets. (BSD-3-Clause)
CUPP	6.6k	2012	2026-07-17 ✅	— biography-derived password wordlist generator. (GPL-3.0)
GoMapEnum	497	2021	2025-09-24 ⏳	— Windows user enum + password spray (SMB/Kerberos/NTLM/LDAP). (GPL-3.0)
Legba	2k	2023	2026-08-14 ✅	— multiprotocol brute-forcer with one CLI. (GPL-3.0)
DonPAPI	1.4k	2021	2026-09-09 ✅	— remote DPAPI credz collection (browsers, Wi-Fi, blobs). (GPL-3.0)
Certify	2k	2021	2026-09-30 ✅	— AD CS abuse toolkit, ESC1-ESC8 chains. (BSD-3-Clause)
airgeddon	8.1k	2016	2026-11-07 ✅	— all-in-one wireless security suite. (GPL-3.0)
SMBMap	2.1k	2015	2026-01-06 ✅	— SMB share enumeration and mapping across subnets. (GPL-3.0)
Medusa	901	2015	2025-05-14 ⏳	— parallel login brute-forcer. (GPL-2.0)

github.com/vinothkannan77/awesome-pentest-security-arsenal · CC0 · Powered by Jekyll + Minimal Mistakes · GPL-2.0

Penelope	2.2k	2021	2026-09-27 ✅	— automated reverse-shell upgrader to full TTY. (GPL-3.0)
Pacu	5.4k	2018	2026-05-19 ✅	— AWS exploitation framework. (BSD-3-Clause)
nomore403	1.9k	2021	2026-10-30 ✅	— 403/401 bypass toolkit. (MIT)
Burp Suite	—	—	—	— Web application and API security testing platform with a free community edition. Used by pentesters and bug-bounty hunters; the industry-standard toolkit for probing web targets. (free tier)
HackRF One	—	—	—	— Open-source software defined radio platform for wireless experimentation, capturing and transmitting signals across a wide frequency range. Used by RF researchers and wireless testers; a popular affordable SDR.
Scapy PFCP Module	—	—	—	— Python packet manipulation library with a PFCP module used for fuzzing 5G N4 interface communications between SMF and UPF. Used by network and telecom researchers; a versatile packet crafting library.
OWASP ZAP	—	—	—	— Open-source web application scanner for finding vulnerabilities through active and passive testing. Used by pentesters and developers; the flagship community web security testing tool. (Apache-2.0)
Vulnify	—	—	—	— Web application security scanner for identifying vulnerabilities, security misconfigurations, and OWASP Top 10 risks with actionable remediation. Used by web security testers; a commercial scanner offering a free tier. (free tier)
Dirb	—	—	—	— Web content scanner that brute-forces directories and files to discover hidden resources. Used by pentesters and bug bounty hunters; a classic Kali tool for content discovery. (GPL-2.0)
Nazar	—	—	—	— Open-source autonomous security and quality scanner for React Native, Flutter, and native mobile projects with 197+ checks. Used by mobile developers; a broad free auditing tool.
KubeXHunt	—	—	—	— Kubernetes post-compromise security assessment tool mapping attack paths from pod to cloud account. Used by cloud attackers and defenders; a free offensive assessment utility.
Ophcrack	—	—	—	— Windows password cracker using rainbow tables for fast recovery. Used by penetration testers and auditors; a classic free offline cracking tool.
CrackStation	—	—	—	— Free online service for cracking password hashes using dictionary attacks. Used by security testers and researchers; a convenient free hash lookup service. (free, proprietary)
Shellter	—	—	—	— Dynamic shellcode injector for Windows executables to bypass antivirus. Used by penetration testers and red teams; a popular offensive payload tool.
OpenOCD	—	—	—	— Open On-Chip Debugger providing JTAG and SWD debugging, programming, and boundary scan for embedded targets. Used by embedded researchers; the de facto open-source debugger. (GPL-2.0)
Ubertooth One	—	—	—	— Open-source Bluetooth monitoring and experimentation platform for wireless protocol reverse engineering. Used by RF researchers; a popular low-cost Bluetooth sniffer. (GPL-2.0)
NetHunter CARsenal	—	—	—	— Kali NetHunter automotive security toolset bundling CAN configuration, VIN decoding, can-utils, and Caring Caribou. Used by mobile pentesters; a convenient Android toolkit. (GPL-3.0)
Project TEMPA v2	—	—	—	— Research toolkit and offensive tools for testing Tesla's Phone-as-a-Key BLE protocol, including VINTAG for recovering vehicle identification numbers. Used by automotive security researchers; a conference-grade deep dive into keyless entry weaknesses.
PyPLCploit	—	—	—	— Vendor-agnostic PLC exploitation and vulnerability discovery framework supporting cross-vendor interaction with Delta, Allen-Bradley, Siemens and others. Used by ICS security researchers; a published academic framework for PLC attack testing.
s7comm_security_framework	—	—	—	— Siemens S7comm security assessment framework supporting PLC information extraction, firmware version identification, program upload, and MITM testing. Used by ICS penetration testers; a targeted toolkit for Siemens control environments.
Quinto	—	—	—	— CLI tool that identifies hash types and orchestrates hashcat and John the Ripper to crack them. Used by penetration testers; a convenient free hash-cracking wrapper.

Dradis	—	—	—	— Collaboration and reporting platform for penetration testers to organize findings and share results. Used by pentest teams; a practical tool for consolidating engagement output.
MagicTree	—	—	—	— Pentesting productivity tool for data aggregation and reporting. Used by penetration testers; a lightweight way to organize findings into reports.
Kali Linux	—	—	—	— Advanced penetration testing and security auditing Linux distribution. Used by pentesters and researchers; a widely adopted offensive security platform.
Parrot Security OS	—	—	—	— Security-focused Linux distribution for penetration testing and privacy. Used by pentesters and privacy advocates; a popular alternative offensive OS.
BackBox	—	—	—	— Ubuntu-based Linux distribution for penetration testing. Used by security testers; a lightweight option for offensive assessments.
BlackArch Linux	—	—	—	— Arch-based Linux distribution bundling over 2800 hacking tools. Used by pentesters and researchers; a large offensive tool collection.
Pentoo	—	—	—	— Security-focused Gentoo-based Linux distribution. Used by pentesters and researchers; a customizable offensive testing environment.
Bugtraq	—	—	—	— Linux distribution for penetration testing and malware analysis. Used by security testers and analysts; a combined offensive and analysis environment.
ArchStrike	—	—	—	— Arch Linux repository providing security tools. Used by Arch users and pentesters; a convenient package source for offensive tooling.
Fedora Security Lab	—	—	—	— Fedora spin for security auditing and testing. Used by security professionals; a ready-made Fedora environment for audits.
NodeZero	—	—	—	— Ubuntu-based penetration testing operating system. Used by security testers; a distribution bundling offensive tools.
GnackTrack	—	—	—	— Linux live distribution for penetration testing. Used by security testers; a bootable offensive testing environment.
PentestBox	—	—	—	— Penetration testing toolkit for Windows. Used by pentesters; a portable Windows environment for offensive assessments.
PayloadsAllTheThings - Server-Sid…	—	—	—	— A curated payload repository covering server-side request forgery exploitation vectors. Used by pentesters and bug bounty hunters; a widely referenced collection of SSRF payloads. (MIT)
PayloadsAllTheThings - Web Cach…	—	—	—	— A payload collection documenting web cache deception techniques and test cases. Used by penetration testers and bug bounty hunters; a practical reference for cache deception testing. (MIT)
PayloadsAllTheThings - Open Red…	—	—	—	— A payload collection covering open redirect exploitation techniques and bypasses. Used by bug bounty hunters and pentesters; a practical reference for redirect testing. (MIT)
PayloadsAllTheThings - SAML Inje…	—	—	—	— A payload collection covering SAML injection attack techniques. Used by pentesters and bug bounty hunters; a practical reference for SAML injection testing. (MIT)
PayloadsAllTheThings - Upload In…	—	—	—	— A payload collection covering insecure file upload exploitation techniques. Used by pentesters and bug bounty hunters; a practical reference for upload bypass testing. (MIT)
SPLOITUS	—	—	—	— Search engine indexing exploits and security tools. Used by pentesters and researchers; a fast exploit discovery service. (free, proprietary)
CFR	—	—	—	— Java decompiler that converts compiled bytecode back into readable source. Used by reverse engineers and security researchers; a capable standalone decompiler.
Pentest Tools - Website Vulnerabi…	—	—	—	— Online scanner detecting SQLi, XSS, command injection, XXE, and 75+ other web app vulnerabilities. Used by pentesters and bug hunters; a hosted web vulnerability scanner. (free tier)